TLP:CLEAR # FSI-ThreatHunting-Report-2025-01

Jan, 2025
금융보안관제센터

FSI Malicious IP 2024

Threat Hunting

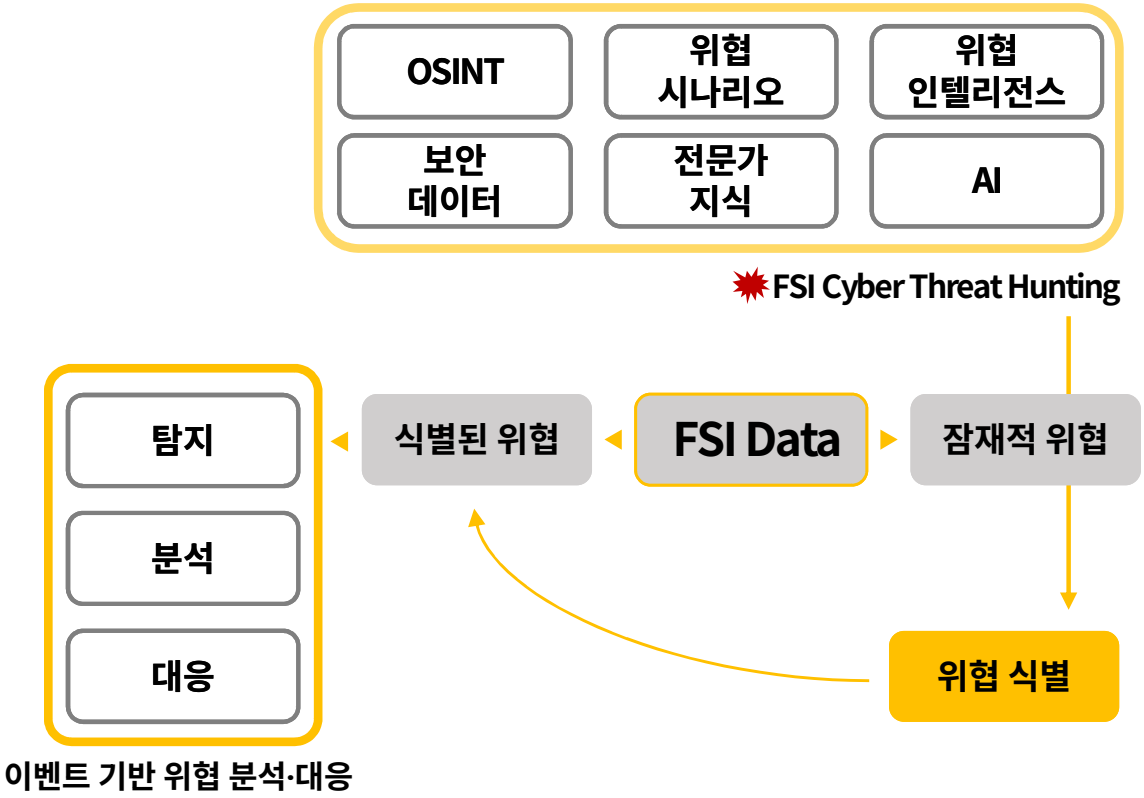
금융보안원
FINANCIAL SECURITY INSTITUTE

FSI Cyber Threat Hunting

사이버 위협 헌팅은 전문 정보보안 분석가 집단이 공개출처정보(OSINT), 위협 인텔리전스, 내부 보안 데이터, 위협 시나리오 등 다양한 경로로 수집한 위협정보와 전문가의 보안 지식, 노하우를 기반으로 내부 시스템과 네트워크를 대상으로 잠재적인 사이버 위협을 식별하고 제거하는 활동이다.

금융보안원은 '23년부터 국내·외 사이버 위협 정보와 금융회사에 설치된 200여 개의 자체 보안관제 센서를 이용하여 금융권의 사이버 위협을 식별하고 제거하는 사이버 위협 헌팅을 수행해 왔다. 이 보고서는 그동안 수행한 위협 헌팅 과정에서의 활동을 기록하고 분석한 보고서이다.

본 보고서를 통해 금융권의 사이버 위협 행위자들의 다양한 공격 방법과 기술을 이해하고, 이를 기반으로 조직의 잠재적 보안 위협을 파악하여, 사이버 위협을 사전에 제거하고 차단하기 위한 전략과 방법을 수립하는 데 활용하기를 기대한다.



요주의 IP

Malicious IP

금융보안원은 국내 200여 개 금융회사의 전자금융서비스 구간을 대상으로 부문보안관제를 수행하고 있으며, 금융회사의 네트워크 구간에 자체 보안관제시스템(관제 센서)을 설치하여 다양한 위협 정보를 수집·분석하고 있다.

금융보안원에서는 일평균 11TB 이상 수집된 데이터와 위협 정보를 기반으로 금융권을 대상으로 하는 공격 IP를 FSI 요주의 IP(Malicious IP)로 별도 지정하여 공격 유형과 특징 등을 종합적으로 분석하고 지속적으로 추적 모니터링하고 있다.

요주의 IP로 지정되면 금융 사이버 위협정보 공유 시스템(FCTI)을 통해 금융회사에 공유가 되며, 요주의 IP로 지정한 IP가 90일간 추가 공격 활동이 없으면 요주의 IP에서 해지가 된다.

본 보고서는 '24년의 금융권 전자금융서비스를 대상으로 한 41,845개 공격 IP의 주요 활동을 추적하고 요주의 IP의 특징을 비교·분석하여 새로운 공격 유형과 패턴을 식별, 요주의 IP의 중요성과 효과성 및 활용 지침을 제공하는 것을 목적으로 한다.

또한, 본 보고서를 통하여 '25년에 금융권 전자금융서비스를 대상으로 하는 사이버 위협을 전망하고 사이버 위협의 탐지와 대응에 대한 통찰을 제공하고자 한다.

요주의 IP (Malicious IP)

금융회사의 전자금융서비스를 대상으로 일일 4개 금융회사 이상, 7일 중 2회 이상 공격한 IP 중 금융보안원이 정한 기준에 부합하는 IP로 90일간 추가적인 공격 활동이 없으면 자동 해지

※ 권고사항 ※

금융보안원에서 제공하는 요주의 IP는 1차 선별된 공격 IP로서 각 금융회사의 서비스 상황과 요주의 IP의 공격 현황을 기반으로, 금융회사에서 자체적으로 활용할 수 있도록 제공되는 FSI Intelligence 정보입니다.

금융 사이버 위협정보 공유 시스템(FCTI)에서 제공하는 요주의 IP 목록은 Security Threat Intelligence 정보로 활용 권고드립니다.

Overview

Statistics of Malicious IP 2024

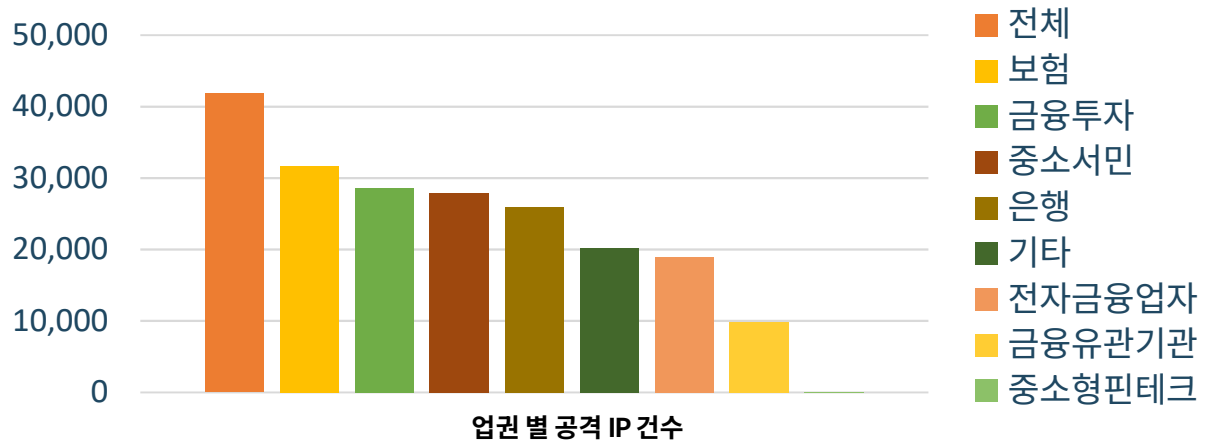
등록 IP 개수	등록 국가 수	등록 AS[1] 개수	전체 대응 건수	공격 IP 활동 수명 주기
41,845 ▼ 13%	**165** ▼ 8%	**3,255** ▼ 53%	**32,983,795** ▲ 12%	**29일** ▲ **1일**

'24년 요주의 IP로 지정된 공격 IP는 총 41,845개로 165개국, 3,255개의 AS이며 공격 IP의 활동 수명 주기(Attack IP Activity Lifecycle)는 **평균 29일**로 분석되었다.

'24년 요주의 IP의 활동을 추적하고 분석한 결과, 요주의 IP로 등록된 건수가 작년과 비교하여 5,999건 감소하였으며 공격 IP의 활동 수명 주기가 작년과 비교했을 때 1일 더 길어진 것을 확인했다.

또한, AS와 국가별 구분하여 살펴본 결과 요주의 IP는 주로 인프라가 잘 구축된 국가의 클라우드나 호스팅 IP가 많이 이용되고 있는 것을 확인했으며, 작년과 비교했을 때 그 현상이 더 두드러진 것이 특징이다.

'24년은 '23년 대비 공격에 활용된 IP와 AS가 적어졌으나 실제 공격 건수는 증가하여 IP 당 공격 횟수가 증가했다.



요주의 IP의 공격 대상을 업권별로 분석해보면 보험(31,631건), 금융투자(28,558건), 중소서민(27,856건), 은행(25,878건), 기타(20,218건), 전자금융(18,870건), 금융유관기관(9,938건), 중소형 핀테크(64건)순이었다.

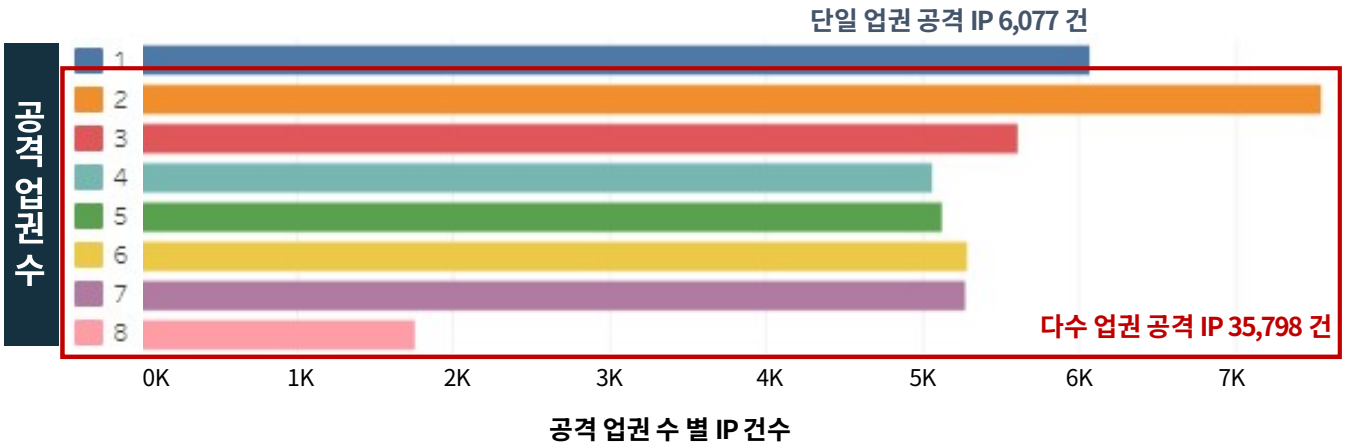
공격 IP 활동 수명 주기 (Attack IP Activity Lifecycle)

일 년 동안 금융보안관제 센서에서 공격 IP가 식별되어 일정기간 공격 활동을 한 후 종료(미식별)되는 공격 활동 주기

1) AS(Autonomous System) : 동일한 라우팅 정책으로 회사나 단체에서 관리하는 라우터 집단

보험	금융투자	중소서민	은행	기타	전자금융	금융 유관기관	중소형 핀테크
31,631 (+4,890) ▲ 18%	**28,558** (-3,648) ▼ 11%	**27,856** (-1,335) ▼ 5%	**25,878** (+2,234) ▲ 9%	**20,218** (+2,342) ▲ 13%	**18,870** (-3,357) ▼ 15%	**9,938** (+1,373) ▲ 16%	**64** (+10) ▲ 18%

'23년과 비교했을 때 보험, 은행, 금융유관기관 업권의 요주의 IP 건수가 증가하였고, '23년에 다수를 차지하던 금융투자와 중소서민의 건수는 감소하였다. 특히, 보험업권이 작년과 비교하여 공격건수가 18% 크게 증가한 것이 특징이다.



각 IP의 공격 대상 업권 수를 분석해 보았을 때, 전체 요주의 IP 중 단일 업권에 대한 공격으로 확인되는 IP는 6,077개 였으며, 이는 전체 요주의 IP 중 약 15%의 IP가 특정 목표 공격에 활용되었다고 볼 수 있다. 그 외 **약 85%의 IP가 2개 이상의 업권을 공격**한 것으로, **다수 IP의 전방위적 스캔 공격 동향**을 확인할 수 있었다.

다음 장에서 '24년 요주의 IP의 주요 특징을 '23년과 비교해서 살펴보도록 하겠다.

Malicious IP in 2023 and 2024

클라우드 IP 활용 공격의 증가

'23년과 '24년의 데이터를 기반으로 '24년의 공격 동향을 살펴보았을 때 중점적으로 확인되는 요소는 **'클라우드 IP 활용 공격의 증가'**이다. '23년 데이터 비교를 통해 그 변화를 명확히 확인할 수 있다.

우선, '공격 IP의 활동 수명 주기'를 살펴보면 '23년 활동 수명 주기는 28.3일이었으나, **'24년은 29.2일로 1일 길어졌다**. 이는 많은 부분의 **공격 IP가 평균적으로 29일간 공격자들에 의해 이용된 후 더 이상 공격에 사용되지 않는 것을 의미**하며, 이는 작년과 유사한 공격 수명 주기이다. 공격 수명 주기에 큰 변화가 없고 요주의 IP 등록 건수가 작년 대비 13% 감소하는 등 표면적 수치로 확인했을 때 우리가 제공하고 있는 요주의 IP를 지금도 많은 금융회사에서 적극적으로 활용하고, 각 금융회사에서 일시적 차단이나 모니터링 대상에 포함하는 등의 적절히 대응하고 있다고 볼 수 있다.

Attack IP Activity Lifecycle

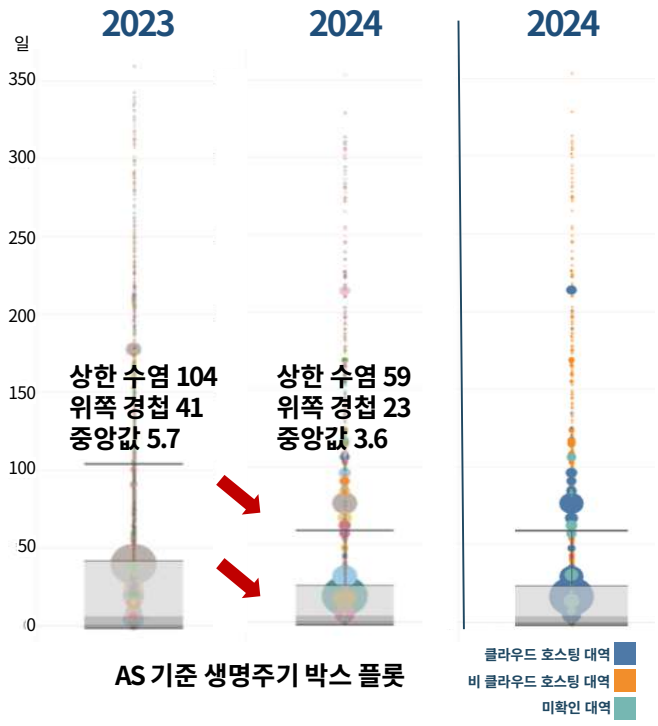
2023 28.3 Days ➡ 2024 29.2 Days

+ 0.9 Days

다만, 단순 통계적 수치로는 유의미한 변화는 없으나 공격 IP를 AS 기준으로 활동 수명 주기를 살펴보면 미세한 변화를 확인할 수 있으며, 이런 공격 트렌드 변화에 민감하게 반응하고 대응해야 한다.

평균 요주의 IP의 생명주기가 0.9일 증가하여 공격자의 IP 활용 기간이 증가한 것으로 보이나, AS 별 생명주기를 박스 플롯을 기반으로 분석해 보면 ' 24년의 상한 수염과 위쪽 경첩이 줄어들어 대다수 IP의 생명주기는 줄어들고, 작년 대비 이상치 값들의 증가로 평균 IP 생명주기가 늘어난 것으로 보인다. 이런 이상치 값들은 특정 IP와 AS들이 중장기간에 걸쳐 공격에 활용되고 있다는 것을 의미한다.

또한, AS 별 평균 생명주기를 보면 클라우드 AS임에도 생명주기가 긴 경우를 다수 확인할 수 있다. 클라우드 IP를 활용하는 공격자는 주기적으로 IP를 변경할

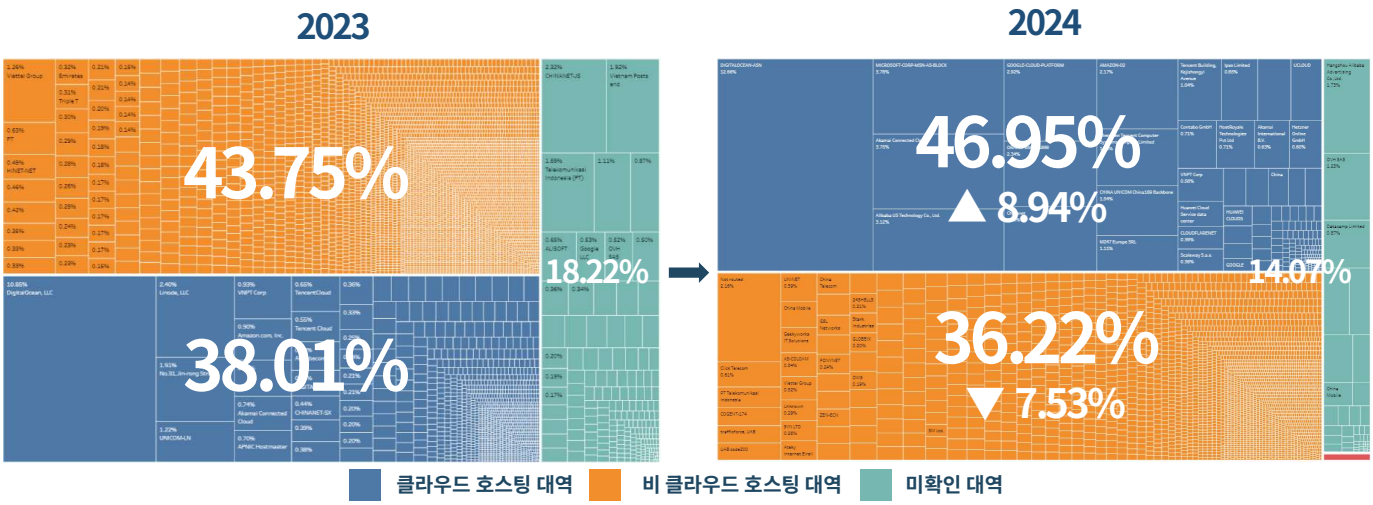


AS 기준 생명주기 박스 플롯

것이라는 관념이 존재하고 실제로도 다수의 AS는 지속적인 변경을 하지만, 특정 공격자들은 구축한 클라우드 서버의 IP를 변경하지 않고 계속 활용하고 있다.

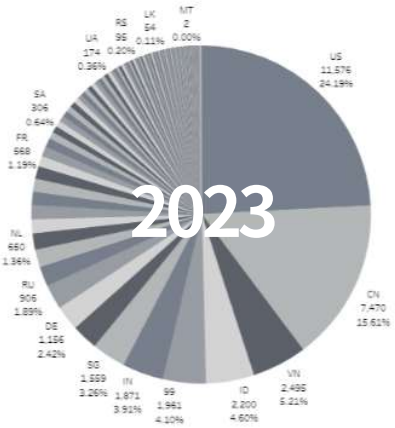
그 다음으로 살펴볼 것이 IP 정보이다. 최근 공격자들은 합법적인 클라우드 서비스를 자주 사용하는데, 그 증가세가 눈에 띄게 나타나고 있다. 해외 언론이나 보안 컨퍼런스에도 "공격자들의 합법적인 클라우드 서비스 사용 증가가 눈에 띄게 증가했다"라고 언급[1,2]하고 있는데, 이는 요주의 IP의 통계에서도 뚜렷하게 나타난다. 공격자는 효율성과 더불어 공격 활동이 합법적인 것처럼 보여 탐지를 회피하기 위해 클라우드 IP를 적극적으로 활용하는 것으로 판단된다.

요주의 IP에서 AS 기준으로 살펴보면 **46% 이상이 클라우드 IP**이며, '23년 전체 요주의 IP에서 38.01%를 차지했던 것이 '24년 46.95%로 **8.94% 증가**하였다. 또한, '23년과 다르게 Google, Alibaba, AMAZON 과 같은 대중적으로 많이 사용되는 클라우드 IP가 증가한 것이 두드러진 특징이다.

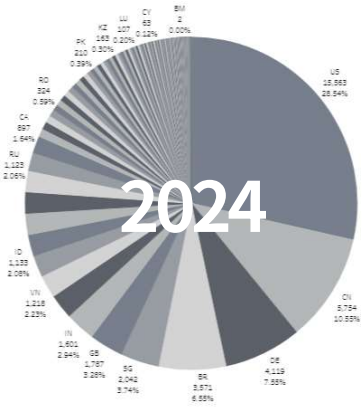


AS 기준 클라우드 분류

요주의 IP를 국가 기준으로 살펴보면, 미국, 독일, 영국 등 주요 국가 IP의 비율이 증가하였고, 중국, 베트남, 인도 등의 IP가 감소하였다.



국가	비율
미국	24%
중국	16%
베트남	5%
인도	5%
인도네시아	4%

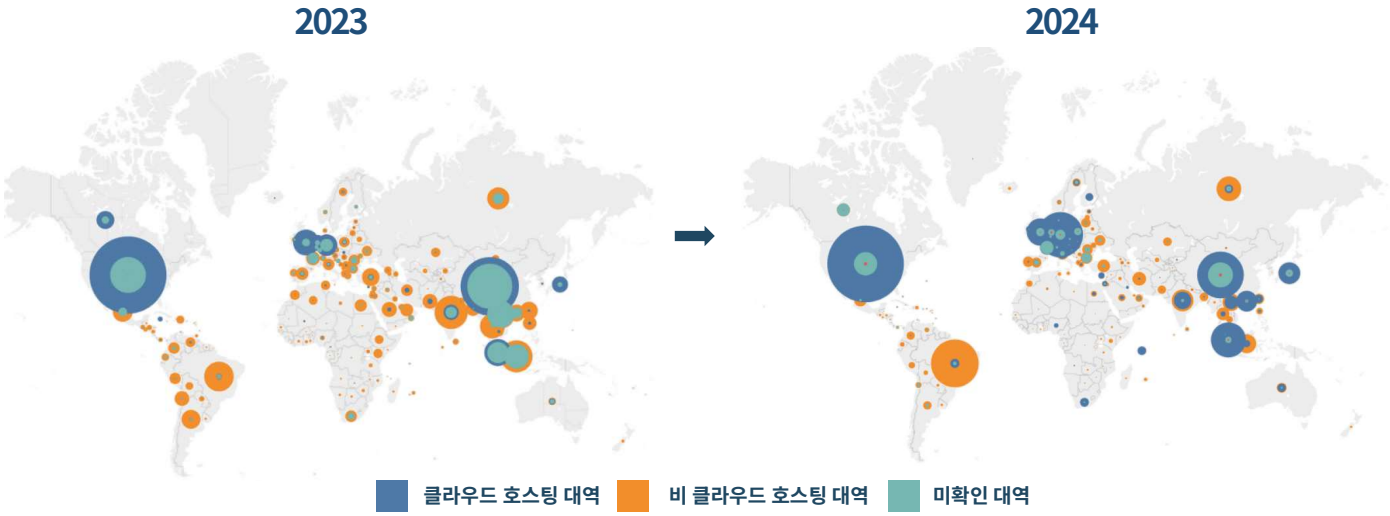


국가	비율
미국	29%
중국	11%
독일	8%
영국	7%
싱가포르	4%

국가 기준 요주의 IP 수

1) https://www.techzine.eu/news/security/123281/state-sponsored-hackers-like-to-set-up-shop-in-legitimate-cloud-services/
2) https://www.security.com/threat-intelligence/cloud-espionage-attacks

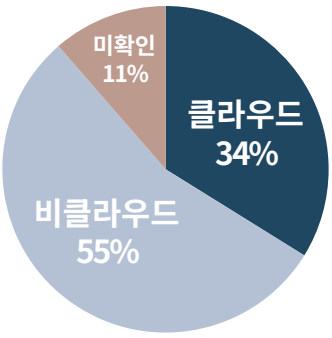
이를 AS의 클라우드 여부와 함께 보면, 미국, 유럽, 동아시아 등 주로 **클라우드 서비스 업체의 데이터 센터가 있는 국가의 클라우드 IP의 비중이 증가**한 것을 볼 수 있다. 클라우드 IP의 사용 증가는 공격자가 자신의 국가 IP가 아닌 다른 국가의 IP로의 공격 시도가 증가할 수 있다는 것을 말한다. 이를 통해 **공격자의 IP와 공격자의 국가 상관성이 더 줄어들었다고 볼 수 있다.**



AS기준 국가별 클라우드 IP 분포

다음으로 공격 IP의 재활용여부를 기반으로 살펴보면, '23년에 등록된 요주의 IP 중 약 19%는 '24년에도 활용되었으며 평균 237일의 재활용 공격 기간을 가지는 것이 확인됐다.

2024년 재활용 공격 IP	비율	재활용 기간
	19%	평균 237일

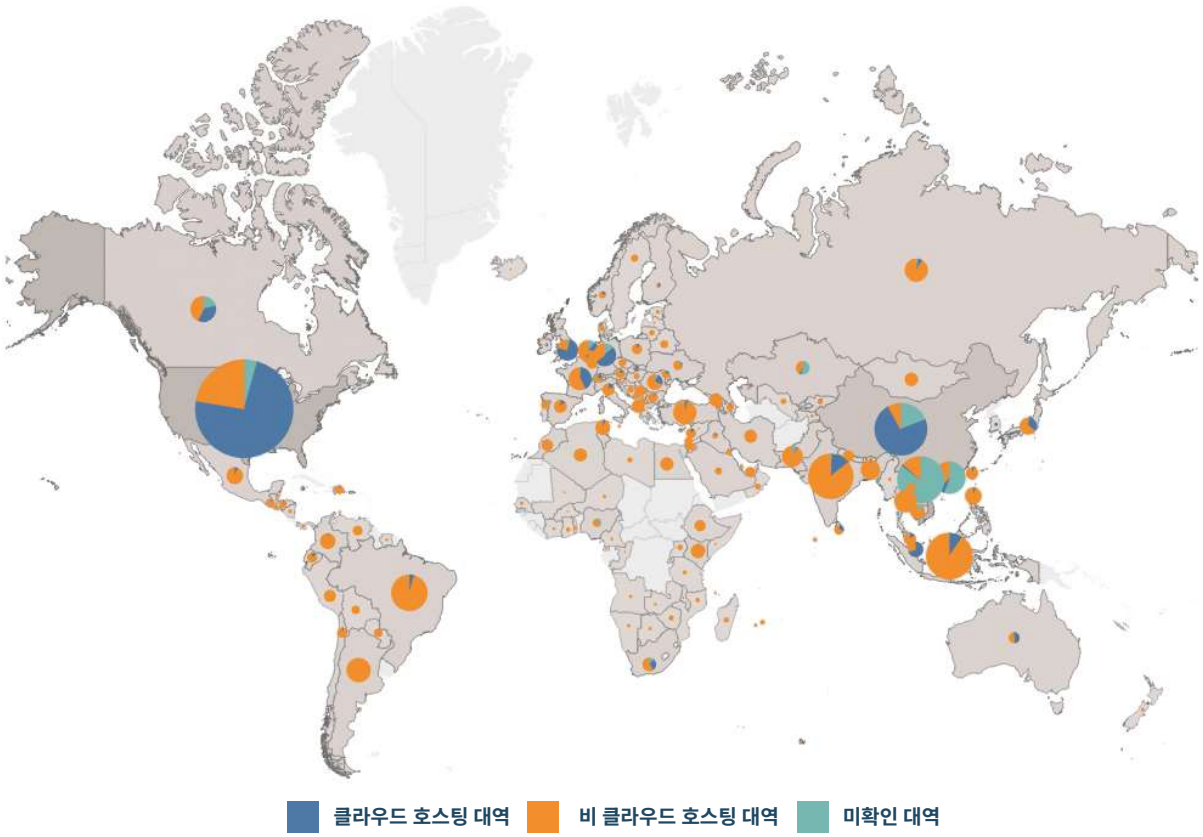


재활용 IP 클라우드 여부

'24년도 재활용된 19% IP를 클라우드 여부로 분류하였을 때 이중 약 55% IP가 비 클라우드 호스팅 대역 IP인데, 이는 '24년 전체 요주의 IP의 약 36%가 비 클라우드 IP인 것에 비해 대조적이다. 이는 IP를 변경하기 어렵거나 감염되어 봇넷(Botnet)화된 단말이 재활용되고 있을 가능성으로 볼 수 있다.

재활용 공격 IP (Recycle Attack IP)

전년도 등록된 요주의 IP가 당해년도에도 공격에 사용된 이력이 있는 IP



재활용 IP기준 국가별 IP 분포

이어서 재활용 공격 IP를 국가 단위로 분석해 보면 클라우드 IP 대역이 미국, 유럽, 아시아 등 주요 데이터 센터가 많은 국가에 분포되어 있던 것과 달리 **재활용 공격 IP는 남미, 중앙아시아, 동남아시아 등에 주로 분포**된 것을 확인할 수 있다. 이는 공유기나 구형 네트워크 단말기 등 즉각적인 보안 조치가 어려운 시스템들이 봇넷으로 악용된 것으로 추정되며, 봇넷화된 단말기들이 공격에 지속적으로 활용되고 있는 것으로 보인다.

하지만, 현재 브라질, 말레이시아, 인도네시아 등 다양한 국가에 클라우드 호스팅을 위한 데이터 센터가 건축되거나 논의되고 있기에 많은 시스템이 클라우드로 전환될 경우 재활용 공격 IP는 줄어들고, 클라우드 IP의 증가세는 더욱 커질 것으로 전망된다.

결론적으로, '23년 대비 '24년에 클라우드 대역의 IP가 요주의 IP에서 더욱 많이 확인되었고, 실제 공격 IP 전반에서 클라우드 IP로 전환이 급격히 빨라지고 있다는 것을 확인 할 수 있었다.

지금까지 '23년 데이터와 비교한 '24년의 요주의 IP 주요 변화를 살펴보았다. 다음 장에서는 위에 언급한 내용과 '24년 FCTI 공유 내용을 기반으로 '24년의 주요 공격 특징을 살펴보도록 하겠다.

2024년 주요 공격 특징 분석

In-Depth Anomaly Analysis of 2024

'24년 요주의 IP와 금융 사이버 위협정보 공유 시스템(FCTI)의 공유 사항을 기반으로 분석해 보면, '24년 공격의 주요 특징을 5가지로 정리할 수 있다.

첫 번째로 '23년의 경우 악성코드 감염 시스템 스캔과 특정 취약점 위주의 스캔이 많았으나, **'24년은 공격표면을 찾기 위한 전방위적인 웹 취약점 스캔 공격이 많았다.**

두 번째로 신규 취약점 발생 시 짧게는 48시간, 길게는 1주일 이내 **즉각적으로 신규 취약점을 찾는 스캔 공격이 확인**되고 있다.

세 번째로 다수의 취약점 스캔 공격은 클라우드 IP를 기반으로 시도되었는데, 그 중 **국내 클라우드 또는 웹 호스팅 IP를 VPN으로 활용하여 공격을 시도**하는 것이 확인되었다.

네 번째로 금융보안원에서 공유한 보안권고문 또는 위협분석 정보로 금융권 대상 웹 취약점 스캔 공격을 분석해 본 결과**, Go 언어를 사용한 취약점 스캔 공격이 다수 확인**되었다. 이는 Go 언어가 공격에 활용하기에 용이하기 때문으로 판단되며, Go 언어를 활용한 DDoS 공격이 외부 동향[1),2)]에서 확인되기도 하였다. 이는 공격자에게 유리한 공격 방식이 추가되었다고 볼 수 있다.

다섯 번째로 **합법적인 클라우드 서비스를 이용하여 조직적이고 체계적으로 웹 취약점 스캔 인프라를 구축**하고, **특정 금융회사 또는 업권을 대상으로 대규모 웹 취약점 스캔을 시도하는 공격 조직을 확인**했으며, 이를 통해 공격자의 주요 공격 방식과 도구의 변화를 확인할 수 있었다.

다음 장에서 위 5가지 특징을 요주의 IP 데이터를 기반으로 상세히 살펴보도록 하겠다.

- 웹 취약점 스캔 공격 증가
- 신규 취약점 발생 시 즉시 공격 증가
- 국내 클라우드 IP를 VPN으로 활용
- Go언어 기반 스캔 및 DDoS 증가
- DIGITAL-OCEAN 등 클라우드 IP 증가

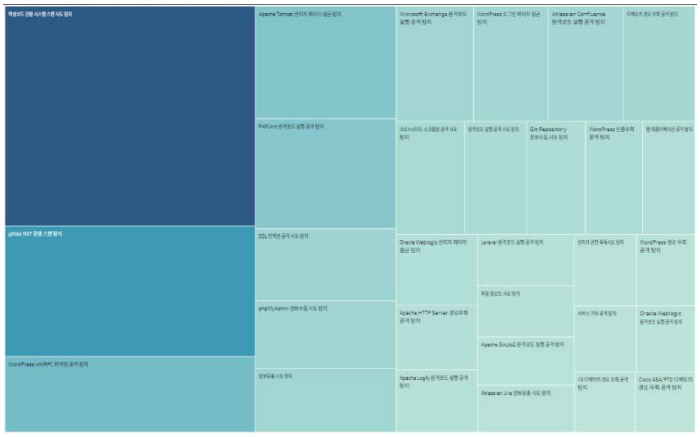
1) https://decoded.avast.io/martinchlumecky/ddosia-project-how-noname05716-is-trying-to-improve-the-efficiency-of-ddos-attacks/
2) https://thehackernews.com/2024/07/new-golang-based-zergeca-botnet-capable.html

① 웹 취약점 스캔 공격 증가

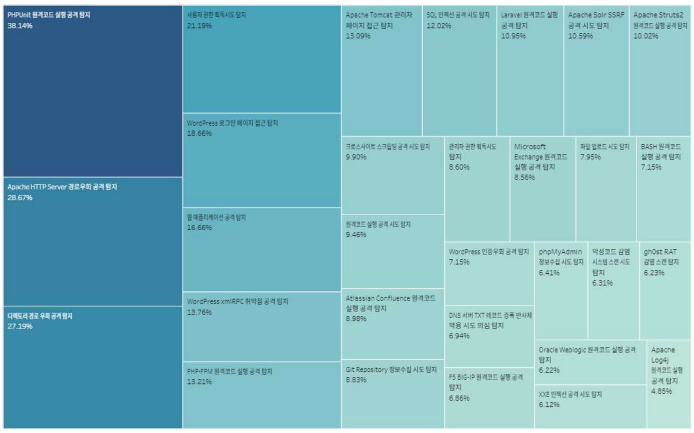
'23년은 등록된 요주의 IP의 대부분은 시스템의 오래된 취약점을 대상으로 하는 공격과 특정 악성코드에 감염된 시스템을 찾기 위한 스캔 공격이 많은 것이 특징이었다. 그와 달리 '24년은 로그인·관리자 페이지에 대한 접근 시도와 디렉토리 경로 우회 등 웹 애플리케이션을 대상으로 한 스캔 공격이 다수를 이룬다.

이는 통계를 통해 명확히 확인할 수 있는데, '23년에는 **악성코드 감염 시스템 스캔 시도 탐지나 gh0st RAT 감염 스캔 탐지**가 많았으나, '24년에는 **PHPUnit 원격코드 실행 공격 탐지, 디렉토리 경로 우회 공격 탐지, Apache HTTP Server 경로우회 공격 탐지 등** 특정 솔루션이나 웹 취약점을 찾는 스캔 공격과 같은 **공격표면을 노리는 공격이 증가**한 것이 특징이다.

2023



2024



요주의 IP 공격유형 비율 TOP 30

2023

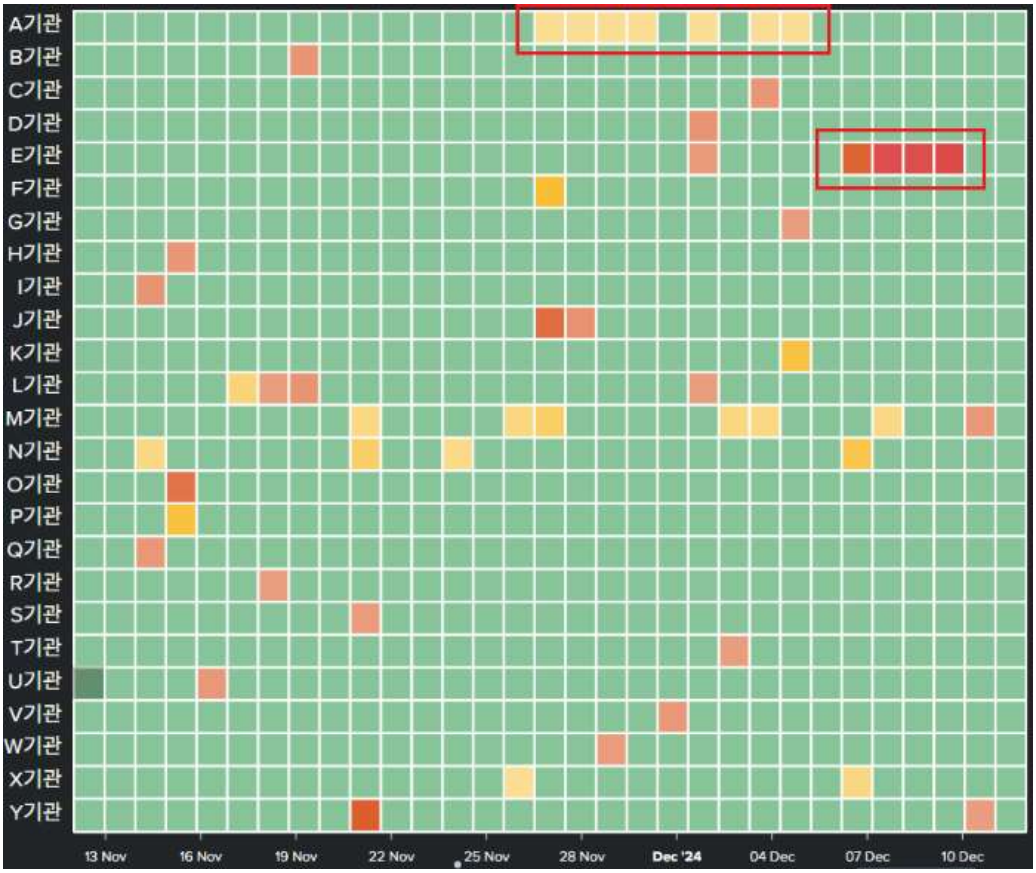
WordPress xmlRPC 취약점 공격 탐지	29%
악성코드 감염 시스템 스캔 시도 탐지	23%
gh0st RAT 감염 스캔 탐지	12%
PHPUnit 원격코드 실행 공격 탐지	9%
Apache Tomcat 관리자 페이지 접근 탐지	8%
SQL 인젝션 공격 시도 탐지	7%
디렉토리 경로 우회 공격 탐지	6%
WordPress 로그인 페이지 접근 탐지	6%
WordPress 인증우회 공격 탐지	6%
크로스사이트 스크립팅 공격 시도 탐지	6%

2024

PHPUnit 원격코드 실행 공격 탐지	34%
Apache HTTP Server 경로우회 공격 탐지	25%
디렉토리 경로 우회 공격 탐지	24%
사용자 권한 획득시도 탐지	19%
WordPress 로그인 페이지 접근 탐지	17%
웹 애플리케이션 공격 탐지	15%
WordPress xmlRPC 취약점 공격 탐지	12%
PHP-FPM 원격코드 실행 공격 탐지	12%
Apache Tomcat 관리자 페이지 접근 탐지	12%
SQL 인젝션 공격 시도 탐지	11%

요주의 IP 공격유형 비율 TOP 10

더불어 이번 웹 취약점 스캔 공격의 특징으로 특정 권역 또는 금융회사를 대상으로 며칠간 지속적으로 이루어진다는 것과, 클라우드와 같은 IT 자원을 활용하여 대규모 스캔이 이루어지는 것이 큰 특징이다. 이들 IP는 다양한 도구를 사용하여 스캔 공격을 시도한다. 특히. 최근 공격자들은 특정 도구(Interactsh)를 활용한 OAST[1] 방법으로 스캔을 다수 진행하는 경향이 있는데, 이를 통해 클라이언트 접속 차단 등 보안 조치를 회피하는 수법을 사용한다.



기관별 일일 스캔 공격 특이사항 발생 그래프

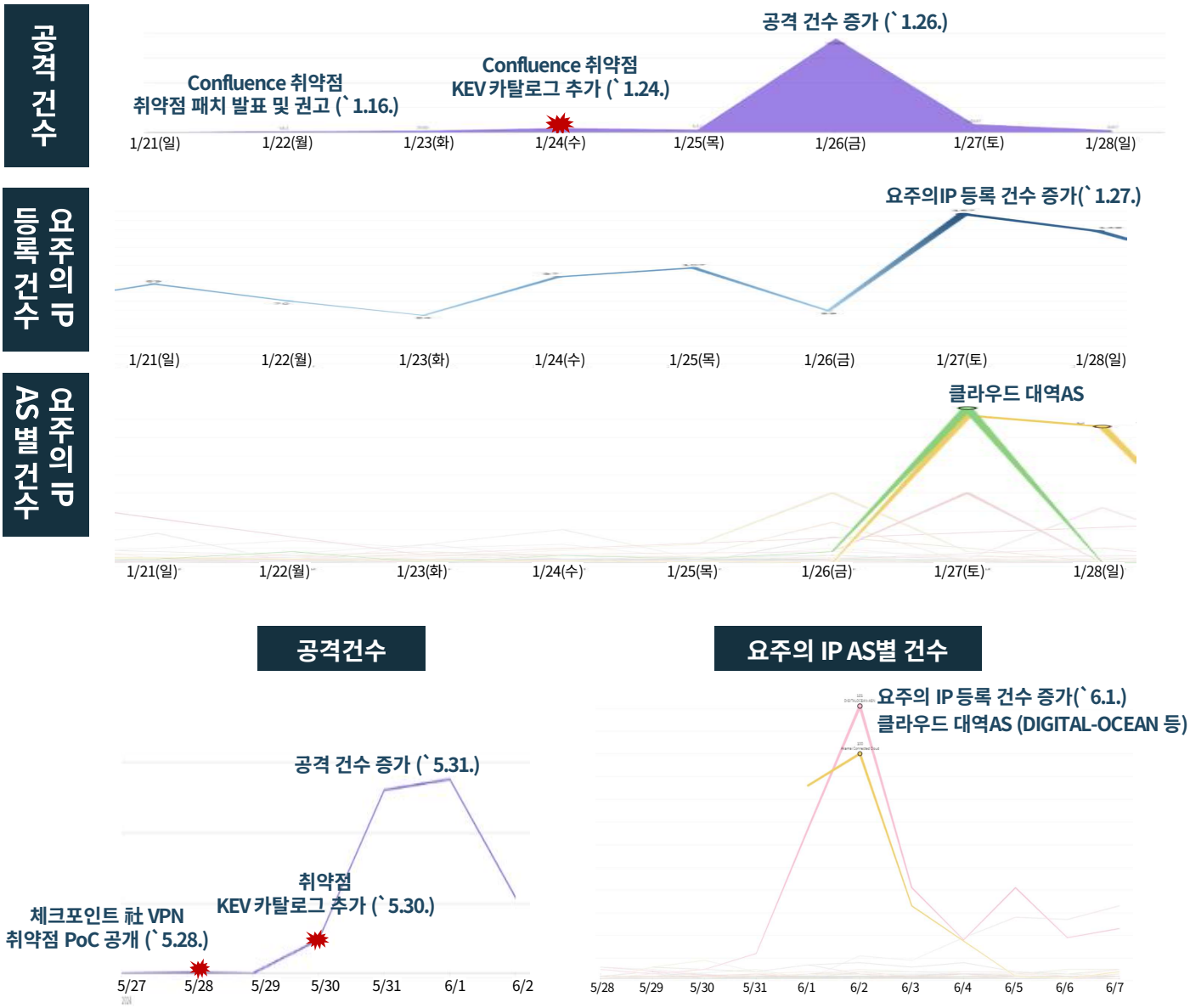
1) OAST(Out-of-band Application Security Testing) : 대상 서버와의 직접적인 통신이 아닌 중간자 서버를 구축하여 웹 취약점 스캐닝 등을 수행

② 신규 취약점 발생 시 즉시 공격 증가

신규 취약점이 발생했을 때 즉각적으로 공격을 시도하는 것은 오래전부터 지속적으로 확인되어 오던 특성이다. 다만, 오늘날 정보의 유통과 활용이 용이해짐에 따라 공격자들은 취약점 정보와 공격코드를 쉽고 빠르게 습득하여 이용할 수 있게 되었다. 이에 따라 신규 취약점을 악용한 스캔 공격은 보통 1주일 이내에 이루어지며, 그 주기는 점점 더 짧아지고 있다.

아래 Confluence와 Checkpoint VPN 취약점 사례로 공격 동향을 살펴보면 신규 취약점이 발견되어 관련 정보 또는 PoC와 같은 공격 코드가 대중에 공개되는 즉시 취약점 스캔 공격이 증가하지는 않지만, 짧게는 48시간(2일) 길게는 1주일 안에 스캔 공격이 이루어지는 것을 확인할 수 있다.

Confluence / Checkpoint VPN 예시



특히, CISA KEV 카탈로그[1] 및 주요 보안 경고가 발표된 이후로 공격이 급증하는 것을 볼 수 있는데, 이는 시차를 고려하면 국경과 관계없이 취약점 스캔 공격이 전 세계적이고 동시다발적으로 이루어진다는 것을 의미한다. 이를 통해 우리는 취약점 발생 시 골든타임을 놓치지 않고 패치를 즉각적으로 진행해야 함을 알 수 있다.

그와 더불어 신규 취약점 발생 이후, 요주의 IP의 등록 건수가 증가하며 이때 등록된 IP는 대체로 클라우드 서비스 IP로 확인이 되고 있다. 이를 통해 우리는 공격자가 클라우드 서비스를 활용하여 체계적으로 스캔 인프라를 구축하고 신규 취약점 공격 코드를 빠르게 업데이트할 수 있는 기술과 능력을 갖춘 전문적이고 조직적인 공격 집단인 것을 알 수가 있다.

결론적으로 가장 중요한 것은 즉각적인 취약점 패치와 관리이지만, 요주의 IP는 다수 기관을 대상으로 공격을 시도하거나 특정 기관에 지속적인 공격을 시도하는 IP를 기반으로 생성되기에 이와 같이 전방위적으로 시도되는 신규 취약점 스캔 IP를 추적 관찰하고 모니터링하는 것이 주요한 인텔리전스가 될 수 있다. 그렇기에 지속적으로 요주의 IP를 활용하는 것이 중요하다.

1) https://www.cisa.gov/known-exploited-vulnerabilities-catalog

③ 국내 클라우드 IP를 VPN으로 활용

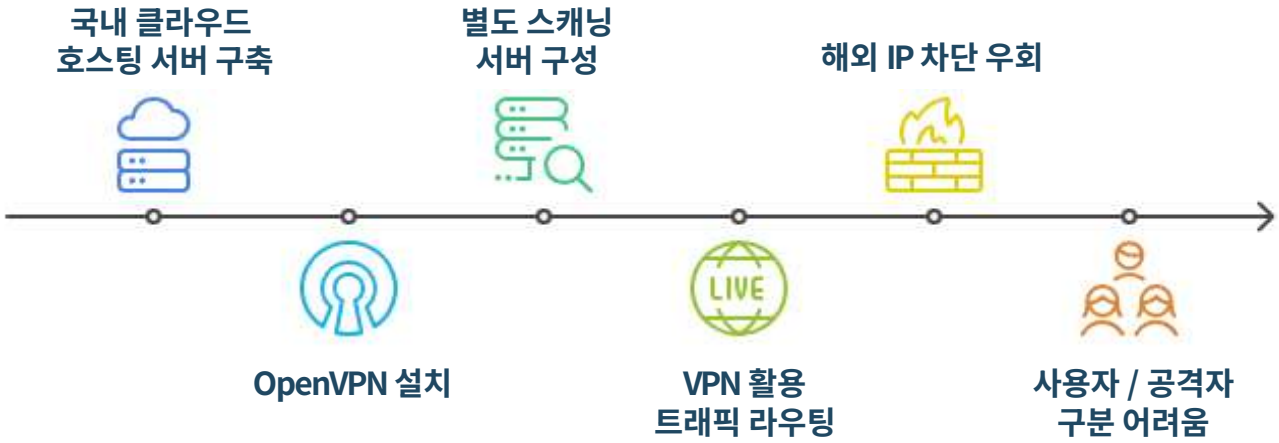
사이버 공격자는 자신을 숨기기 위해 보통 취약한 서버나 네트워크 시스템을 해킹하여 악용하는데, 최근에는 합법적인 VPN이나 클라우드 서비스를 이용하는 경우가 점점 늘어나고 있다.

금융보안원은 소비자 피해 예방을 위해 기본적으로 국내 IP를 요주의 IP로 등록하지 않고 있으나, 주요 공격에서 확인된 명확한 공격 IP의 경우는 별로도 요주의 IP로 등록하고 있다.

또한, 클라우드는 서비스 특성상 국경의 제약이 없기 때문에 클라우드 서비스를 활용한 공격 IP는 금융회사의 서비스에 영향을 줄 가능성이 있어 예외적으로 요주의 IP로 등록하지 않는 경우가 많다. 하지만, 국외 클라우드 IP뿐만 아니라 국내 클라우드 IP(국내 리전)를 이용한 공격이 점차 증가하고 있어 우려를 낳고 있다.

국내 클라우드 IP를 이용한 취약점 공격 추이

최근 공격자는 국내에 구축된 클라우드 호스팅 서버에 OpenVPN을 설치하고, 별도 구축한 스캐닝 서버에서 VPN이 설치된 클라우드 호스팅 서버로 네트워크를 경유시켜 공격하도록 설계하기도 한다. 이는 해외 IP 차단으로 공격을 방어하는 기법을 우회하고, 실제 국내 사용자와의 구분이 어려워 공격을 방어하기 어렵게 만든다.



국내 클라우드 IP를 활용한 취약점 공격 사례

공격자는 Nuclei 스캐너를 통해 취약점을 스캔하고 응답 값을 확인하기 위해 Interactsh를 활용한 것으로 확인되었다. 이처럼 특정 도구가 공격에 활용됨이 확실한 상황에서도 방어하기가 쉽지 않고, DDosia와 같이 공격 목적지 국가 IP로 변경해서 공격을 진행하는 사례도 있어 주의가 필요하다.

국내 클라우드 IP를 활용한 취약점 공격 사례

④ Go언어 기반 스캔 및 DDoS 증가

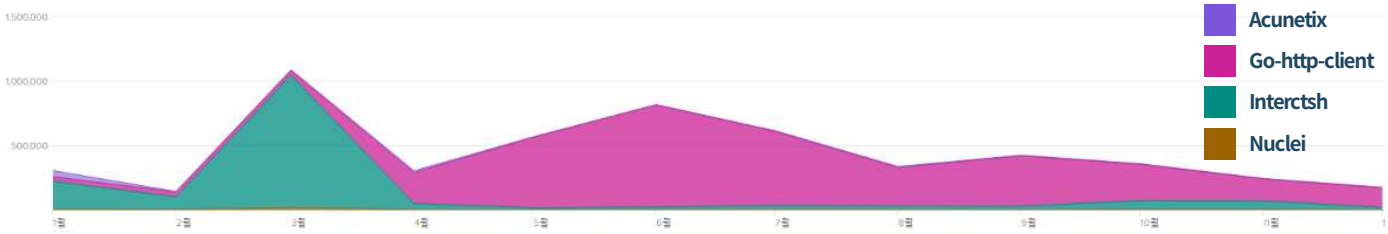
2024년은 국제 정세의 혼란으로 핵티비즘 성격의 사이버 공격이 국내·외를 막론하고 다수 관측되었다.

특히, 친러시아 해커 그룹인 NoName057(16)이 주도하는 DDosia 프로젝트[1] 와 HinataBot과 같은 Go 언어 기반의 DDoS 공격도 활발하게 발생[2]했으며, 북한의 김수키 또한 Go 언어 기반의 백도어를 배포[3] 하기도 하였다.

이와 더불어 DDosia가 2023년 Python에서 Go로 재구현된 이후, 각종 보안 커뮤니티와 컨퍼런스를 통해 User Agent에 “Go-http-client”가 포함된 스캔성 로그가 증가하고 있는 동향이 함께 확인됐다. 이는 DDosia나 다수의 공격 도구가 User Agent를 조작하여 트래픽을 전송함에도 불구하고 Go 언어 기반의 공격이 증가하는 현 상황을 보여준다.

해외 Go 언어 기반의 공격 동향

금융보안원에서도 '23년 대비 '24년에 Go 언어 기반의 스캔성 트래픽 증가를 확인하였다. '24년 취약점 스캔 공격 중 Go 언어 기반의 공격 도구를 이용한 공격이 가장 높은 비율을 차지하였으며, 공격 도구가 식별된 '23년 전체 공격 IP는 2,675개, 24년에선 15,772개로 **약 490%로 증가**한 것을 확인했다. 요주의 IP에서 확인된 Go 언어 기반 공격 IP도 383개에서 2,934개로 **약 666%의 증가**가 있었다.



2024년 공격 도구별 취약점 스캔 공격 건수

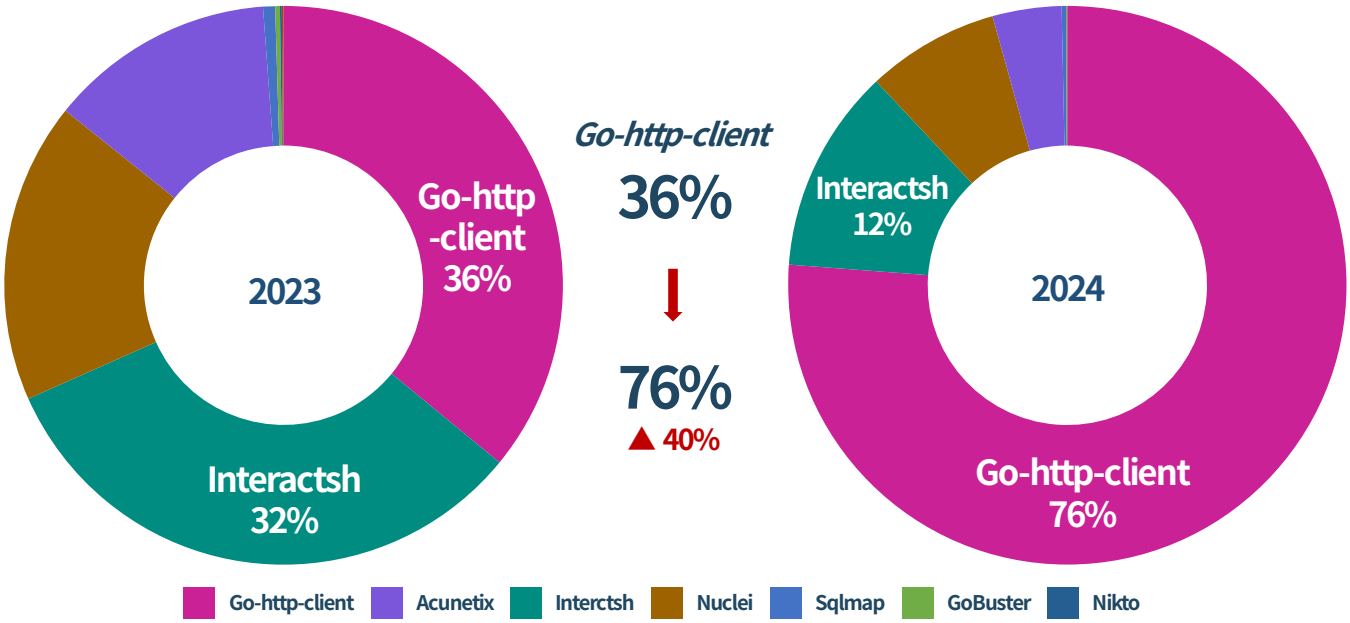
Go-http-client 변화

2023년 전체 IP	2024년 전체 IP	증감률
2,675	15,772	▲ 490%

2023년 요주의 IP	2024년 요주의 IP	증감률
383	2,934	▲ 666%

1) https://decoded.avast.io/martinchlumecky/ddosia-project-how-noname05716-is-trying-to-improve-the-efficiency-of-ddos-attacks/
2) https://www.akamai.com/blog/security-research/hinatabot-uncovering-new-golang-ddos-botnet
3) https://thehackernews.com/2024/02/kimsukys-new-golang-stealer-troll-and.html

다른 공격 도구와 함께 묶어서 확인해보면 약 40%의 비율이 증가했음을 알 수 있다. 공격 도구를 활용한 공격 IP의 수가 크게 변화가 없는 상황에서 “Go-http-client” 트래픽만 유의미하게 증가하였다.



공격 도구 식별 IP 비율

Go 언어 기반 취약점 스캔 도구들을 보면 단순하게 Go 언어의 특정 네트워크 패키지들을 사용한 것이 많아, 취약점 패턴 + User Agent(Go-http-client)로 되어있어 개별 식별이 어려운 편이다. 이에 기본적으로 Go 언어를 사용하여 다수의 공격 패턴을 발생시키는 것이 일반 사용자일 가능성은 희박하다는 전제를 가지고 분석하고 있다. 공격은 대다수 웹 어플리케이션 공격이었으며 DIGITAL-OCEAN 대역을 활용한 공격 IP가 23%를 차지했다. 국가별 특성으론 미국의 IP가 4%만 확인되고 다수의 네덜란드와 독일 IP가 식별되었다.

웹 어플리케이션 공격 탐지 64%

DIGITAL-OCEAN 23%

네덜란드 30% 독일 28% 미국 4%

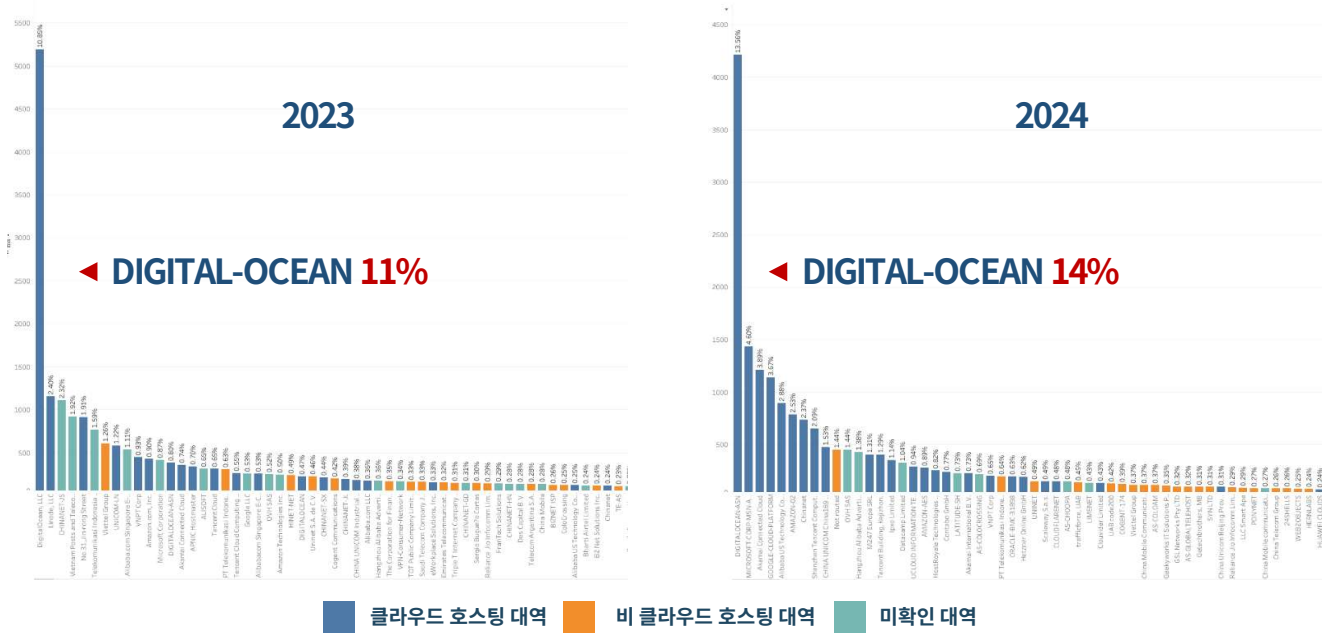
Go 언어 기반의 웹 취약점 공격이 폭발적으로 증가하고 있는 이유는 Go 언어가 경량성과 고성능의 다중스레딩, 멀티플랫폼 지원을 이용해 빠르게 배포할 수 있는 장점[1)]을 가지고 있어 공격자가 쉽게 서버를 구축하여 취약점 스캔이 가능하기 때문으로 판단된다.

Go 언어 기반의 취약점 스캔 공격은 특정 공격 도구로 판단하기 난해한 부분이 있고, 경량성과 효율성으로 인하여 시간이 갈수록 공격에 악용될 가능성이 높아 보인다. 이는 결과적으로 공격자의 공격이 더욱 빠르고 강력해진다는 것을 의미한다.

1) https://go.dev/solutions/case-studies

⑤ DIGITAL-OCEAN 등 클라우드 IP 증가

앞서 본 것과 같이 **'24년 요주의 IP의 큰 특징은 클라우드 IP 증가**이며, '23년 대비 '24년에 약 9% 증가했다. 그중 Microsoft, Google Cloud, Amazon 등 비교적 인프라가 큰 글로벌 회사의 IP가 다수 공격에 활용되고 있음을 확인했다. 클라우드 IP 중 DIGITAL-OCEAN은 요주의 IP 중 가장 많은 14%의 비율을 가지고 있었으며, '23년 대비 3%가 증가했다. 다른 클라우드 IP보다 DIGITAL-OCEAN이 유난히 많은 이유는 비용적 이점과 IP 변경 등 운용의 자율성이 높아 공격자들이 선호하는 것으로 판단된다.



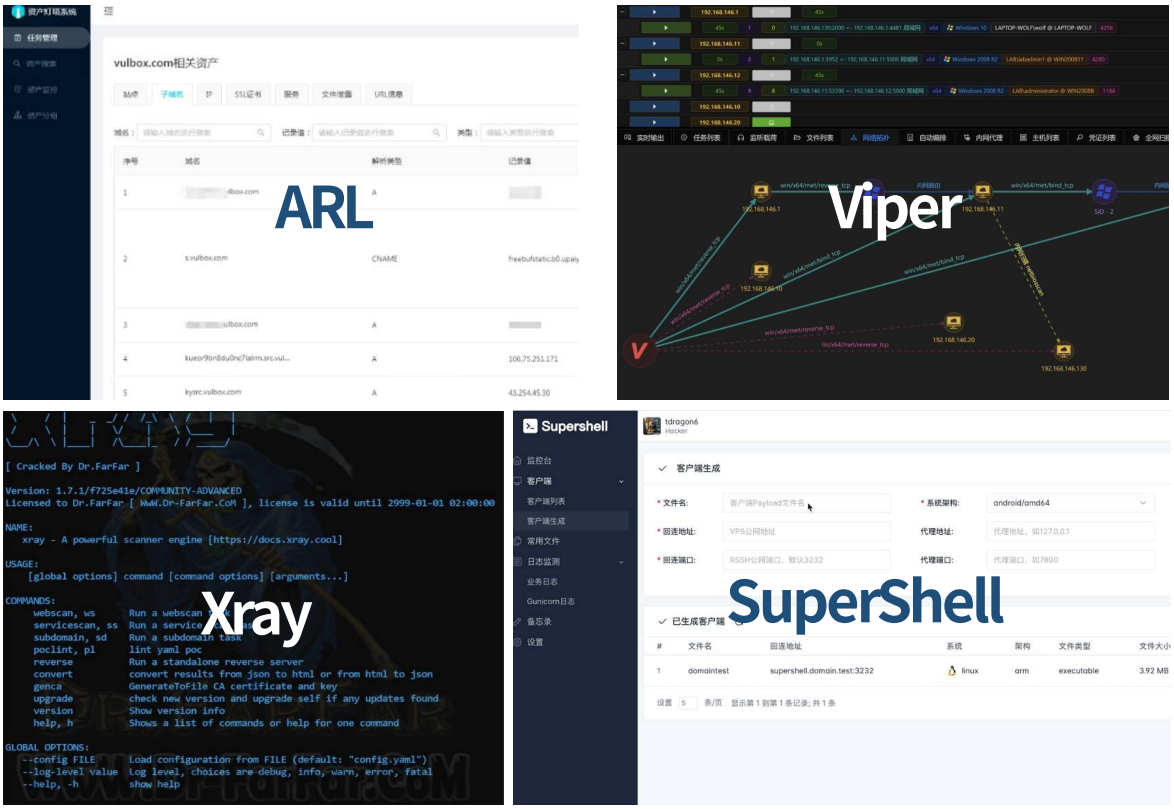
AS 별 비율 그래프

DIGITAL-OCEAN IP는 그간의 금융보안원 위협동향 보고에도 지속적으로 언급되었으며, 주로 확인되는 사항은 서브도메인 스캔과 디도스 공격을 포함한 특정 도구를 활용한 공격이다. 2024년 NXDomain Hunter[1)]에서 공유한 바와 같이 공격자들은 공격의 첫 번째 단계에서 취약한 공격 대상을 찾기 위해 정보수집(Reconnaissance)을 하는데, 정보를 수집하기 위한 여러 방법 중 하나가 잠재적 위협이 존재하는 대상을 찾기 위한 특정 도메인의 서브도메인을 스캔하는 것이라 언급했다. 서브도메인 스캔 시 공인된 인터넷 인프라 제공업체의 내부 DNS 리졸버가 식별되었고 이때도 DIGITAL-OCEAN IP가 많이 식별되었으며, 2024년에 발생한 금융회사 대상 디도스 공격에도 DIGITAL-OCEAN IP가 다수 식별되었다.

또한, '24년에는 금융회사 대상으로 다량의 웹 취약점 스캔 공격이 빈번히 발생하여 관련 정보를 공유했는데, 이때에도 DIGITAL-OCEAN IP를 필두로 한 클라우드 IP에서 중국 배후에 있는 공격자들이 취약점 스캔 도구를 사용하고 있는 것을 확인했다. 우리는 탐지된 공격 정보와 OSINT 등을 다양한 정보들을 종합하여 공격 IP를 분석하였고, 이 과정에서 **(1) Nuclei, Acunetix, Interactsh 등 다양한 웹 취약점 도구를 결합하여**

1) https://www.fsec.or.kr/bbs/detail?menuNo=244&bbsNo=11509

사용, (2) Xray, ARL, Viper, SuperShell 등 다양한 공격 도구를 보유하고 활용, (3) 다수 공격 도구에서 중국 공격자가 사용한 흔적 등 여러 정황들을 확인 할 수 있었다. 이를 통해 **중국 배후의 해킹그룹이 클라우드 인프라를 활용하여 조직적으로 스캔을 수행하고 있는 것으로 추정**하고 있다.



클라우드 인프라를 활용한 취약점 스캔 도구

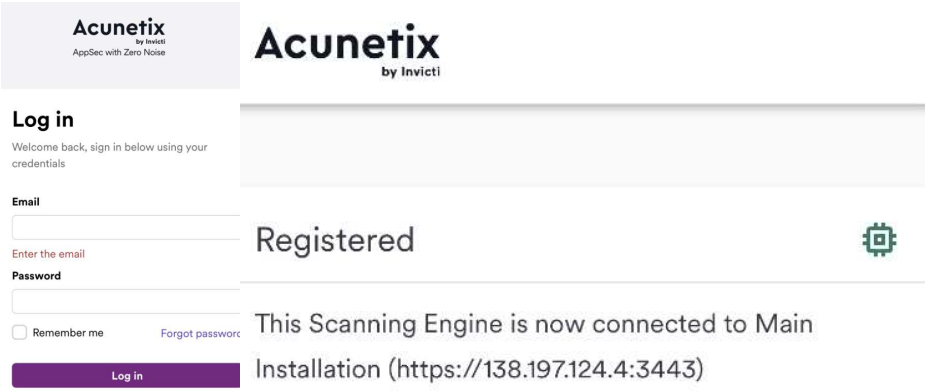
여러 사례 중 한 사례를 살펴보면 공격자는 Acunetix 스캐너를 활용해서 다양한 금융회사를 대상으로 스캔 공격을 수행했는데, 이때 공격자는 클라우드 호스트에 Acunetix 스캔 인프라를 구축하여 다수 스캔 공격을 시도하였다. 공격자는 메인 스캐너와 다수의 스캐닝 엔진을 모두 DIGITAL-OCEAN에 구축하였고, 효과적인 공격을 위해 Nuclei 스캐너를 부가적으로 활용하였으며 이때도 중국 배후의 공격자로 보이는 정보들이 식별되었다.

이러한 사례를 바탕으로, 올해 취약점 스캔 도구를 활용한 공격에 이용된 IP의 국가를 확인해 보면 7,562건 중 310개로 중국 국적의 IP는 소수에 불과하였다. 이는 위 사례와 같이 특정 국가의 IP로 공격이 확인되어도

[중국배후 취약점 스캔 공격에 사용된 도구]

(Xray) 취약점 스캔 도구, '패시브 스캐닝', '액티브 스캐닝', '서비스 스캐닝' 등 다양한 기능을 지원
(ARL) Asset Reconnaissance Lighthouse, 공격 대상의 자산을 탐지하고 공격 영역을 식별하는 도구
(Viper) 공격 표면 기반 공격 도구 및 브라우저 기반의 인트라넷 침투 도구
(SuperShell) C2 제어 웹서비스 플랫폼

인프라 이용자는 중국 배후 공격자인 것처럼 공격자의 실제 거주 혹은 국적이 공격 IP의 국가와는 동일하지 않다는 것을 의미한다. 즉, 공격자들은 자신을 은폐하고 조직적이고 체계적인 사이버 공격을 위해 침해된 서버, 클라우드 또는 VPN 서비스 등을 이용한다는 것을 의미한다.



공격자가 클라우드에 Acunetix 메인 스캐너와 다수 스캐닝 엔진을 구축하여 운영

이러한 현상은 최근 해외 분석 보고서에도 언급되었는데, 구글 맨디언트에 따르면 중국 배후의 공격자는 사이버 위협 활동에 대규모 ORB 네트워크를 사용하고 있으며 지속적으로 사용량이 증가할 것으로 예상하고 있다고 언급했다.[1] 해당 보고서에 ORB 네트워크에 주로 사용되는 AS가 공개되었는데, '24년도 등록된 요주의 IP의 AS와도 일부 겹친다. 공격자는 ORB 네트워크처럼 변동성이 높은 침투 경로를 적극적으로 활용할 것이며, 방어자의 시간·비용적 부담은 지속적으로 증가할 것이다.

ORB 주요 AS	요주의 IP 개수
Shenzhen Tencent Computer Systems Company Limited (CN)	651
OVH SAS (FR)	448
Hangzhou Alibaba Advertising Co.,Ltd. (CN)	429
Tencent Building, Kejizhongyi Avenue (CN)	402
AS-CHOOPA (US)	149
Stark Industries Solutions Ltd (UK)	54
Kaopu Cloud HK Limited (HK)	32
BrainStorm Network, Inc (CA)	3
Green Floid LLC (PL)	3
TWC (US)	-

요주의 IP 내 ORB 네트워크

결론적으로 클라우드 IP를 기반으로 한 공격 인프라 구축과 이를 이용한 공격 시도는 앞으로도 꾸준히 있을 것으로 예상된다. 특히, 비용적으로 저렴하고 상대적으로 보안 관리감독이나 규제에서 자유로운 저가 클라우드로 많이 이동할 것으로 전망된다.

1) ORB(operational relay box networks) : 가상서버(VPS)·IOT 장치·라우터 등으로 구성된 복잡하고 계층화된 네트워크로, 주기적으로 인프라가 교체된다.
https://cloud.google.com/blog/topics/threat-intelligence/china-nexus-espionage-orb-networks/?hl=en

결론
Conclusion

사이버 보안은 창과 방패의 싸움이라고 말하며 시간이 갈수록 더 치열해지고 있다. 방패를 가지고 있는 방어자의 입장에서는 끊임없이 공격자의 평소 행동 하나하나 미세한 변화에 관심을 가져야 하며, 미래의 위협 시그널을 제대로 읽고 대비해야 한다. 즉, 현재 상황을 통해 미래를 예측할 수 있는 통찰력(선견지명)이 필요한데, 그 이면에는 현재 상황을 정확히 분석하고 판단할 수 있는 데이터가 있다.

우리가 Malicious IP 2024를 제공하는 이유도 여기에 있다. 명확한 데이터를 통해 '24년 공격의 동향을 분석하고 '25년의 공격 트렌드를 예측하는 데 있다. 우리는 '24년 Malicious IP를 통해 **①공격자가 공격에 활용하는 IP가 클라우드 호스팅 서비스의 IP로 이동**하고 있는 것을 볼 수 있었고, **②공격자들은 Go 언어 기반으로 한 가볍고 생산성이 좋은 공격 도구를 이용**하고 있다는 것도 파악했다. 또한, **③합법적인 클라우드를 통해 조직적이고 체계적인 취약점 스캔 인프라를 구축하는 해킹 조직이 있다**는 것과 **④오래된 취약점부터 최신 취약점까지 지속적으로 공격표면을 찾는 행위가 끊임없이 이루어지고 있다는 것**을 알았다.

이를 통해 우리는 '25년의 공격 트렌드를 조심스럽게 예측하고자 한다. 우선, '24년 데이터에서도 보았듯이 **①공격자는 비용과 운영의 효율성이 좋은 클라우드 서비스를 더 많이 이용할 것**이며, 국가 배후 해킹 그룹과 같은 **②조직적이고 전문적인 공격자들은 ORB 네트워크를 이용하여 유연한 해킹 인프라를 구축하여 특정 기업 또는 산업군을 대상으로 대규모 취약점 스캔 공격을 수행할 것으로 예측**된다. 또한, 오래된 취약점부터 최신 취약점까지 **③공격표면을 찾는 취약점 스캔 공격은 앞으로도 꾸준히 발생**할 것이며, 이런 활동으로 취약한 네트워크나 IoT 장비 등이 디도스 봇넷(DDoS Botnet)으로 악용될 것이다. 이에 따라 **④다양한 산업군에 정치적 또는 사회적 목적의 디도스 공격이 빈번하게 발생**할 것으로 예측된다.

마지막으로 '24년도를 지나면서 공격자도 고성능의 LLM을 저렴한 비용으로 쉽게 사용 가능할 수 있기에, **⑤워크플로우 자동화 도구를 기반으로 AI를 융합하거나 LLM 자체를 취약점 공격에 활용**할 것으로 보인다.

따라서 이제는 공격자가 특정 취약점이나 공격 도구를 시간을 가지고 만들어 가기 보다는 모든 ⑥**취약점 요소에 대해서 공격자가 구축한 자동화 프로세스로 즉각적인 취약점 공격을 수행**할 것이다. 이에 보안관제 측면에서 모든 공격표면 요소를 제거하지 않는 한 공격의 성공 가능성은 언제나 존재한다고 본다.

FSI Threat Hunting Report-2025-01

2024 요주의 IP

FSI Malicious IP 2024

작성자 금융보안원 금융보안관제센터

본 문서의 내용은 금융보안원의 서면 동의 없이 무단 전재를 금합니다.
본 문서에 수록된 내용은 고지없이 변경될 수 있습니다.

금융보안원
FINANCIAL SECURITY INSTITUTE